

SSH Brute-Force Attack

Vulnerability Assessment & SIEM Detection Report

Author: Pervis Harden — Cybersecurity Analyst / Ethical Hacker | Date: June 3, 2026 | Environment: "Namek"
Homelab (isolated)

Classification: Lab / Educational | SIEM: Wazuh v4.12.0 (manager: ubuntu-srv01)

1. Executive Summary

A controlled SSH brute-force (password-guessing) attack was launched from the lab's Kali Linux attack host (Frieza, 10.10.10.219) against a **single target — the Windows 11 host at 10.10.10.20**, which runs OpenSSH for Windows. This was a direct host-to-host attack, not a network-wide sweep. It used **Hydra** and the **rockyou.txt** wordlist against the root account. The objective was twofold: demonstrate the offensive technique, and validate that the **Wazuh SIEM** detects and surfaces the activity.

The attack was **successfully detected**. Within the monitoring window the SIEM recorded **16,420 total alerts**, including **~10,700 authentication failures** and **4 critical (level 12+) alerts**, and mapped the behavior to MITRE ATT&CK techniques including **Brute Force**, **Password Guessing**, and **Valid Accounts**. The root cause is a target permitting **remote password authentication for a privileged account with no rate-limiting, lockout, or MFA**. Remediation steps are provided in Section 8.

Key finding: CRITICAL — Remote SSH service permits password-based authentication for the root account with no brute-force protection, allowing unlimited automated password guessing.

2. Lab Environment

Host	Role	OS	Address
Frieza	Attacker (source of the brute-force)	Kali Linux	10.10.10.219
windows-cli01	Target — the only host attacked (OpenSSH for Windows)	Windows 11	10.10.10.20
Goku	SIEM / Manager	Ubuntu Server	ubuntu-srv01

All systems reside on the isolated Namek virtual network (10 . 10 . 10 . 0/24, NAT disabled, no internet egress). The attack was a **direct, single-host engagement from Frieza to windows-cli01** — no other hosts were scanned or targeted. Wazuh agents on the endpoints forward authentication telemetry to the manager on Goku.

3. Attack Execution

The attack was performed from Frieza (Kali) using **Hydra**, a parallelized network login cracker. A single command targets the SSH service, fixes the username to root (-l), and iterates every password in the rockyou wordlist (-P):

```
$ hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://10.10.10.20
```

Parameter	Meaning
hydra	Parallel brute-force / credential-cracking tool
-l root	Single target username: root (a high-value, privileged account)
-P /usr/share/wordlists/rockyou.txt	Password list — ~14 million common, leaked passwords
ssh://10.10.10.20	Protocol and target: SSH on the single Windows 11 host (OpenSSH for Windows) — one IP, no network sweep

Hydra opens many parallel SSH sessions and attempts each candidate password in rapid succession — generating a high-volume burst of failed authentication attempts that is the signature of this attack.

4. Detection & Evidence (Wazuh)

The brute-force activity produced an unmistakable spike in the Wazuh dashboard. The authentication-failure count and the level-12+ alerts directly correspond to the attack window.

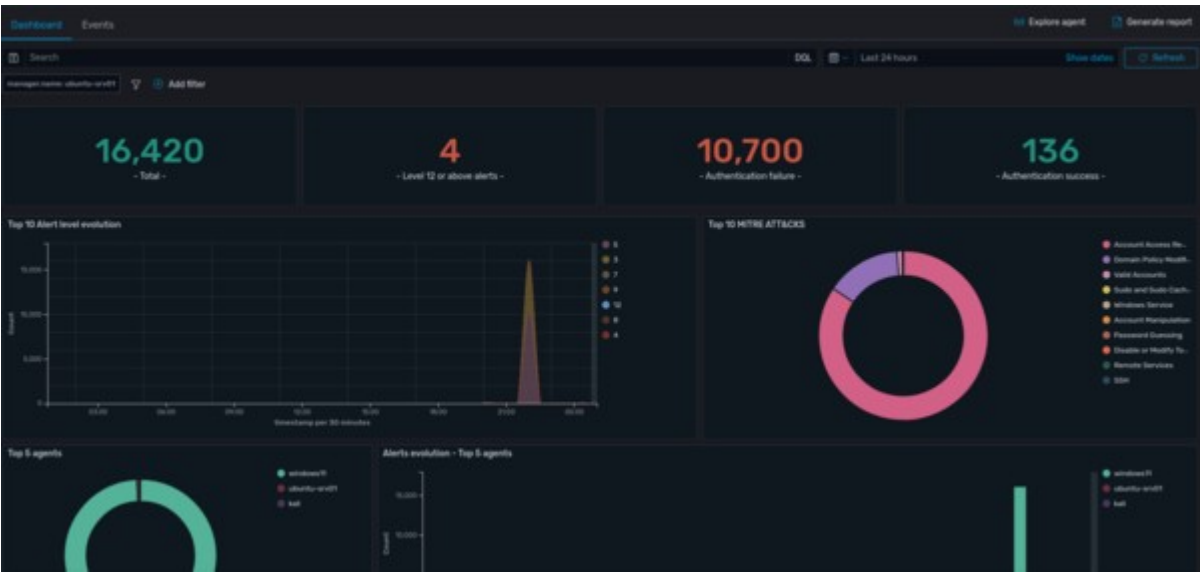


Figure 1 — Wazuh dashboard during the attack window (full-resolution image in the repo's asset s/).

Metric	Value	Interpretation
Total alerts	16,420	Overall event volume in the window
Authentication failures	10,700	The brute-force password-guessing flood
Authentication successes	136	Baseline / legitimate logons
Level 12+ (critical) alerts	4	High-severity correlated alerts (e.g. multiple failures / queue flooding)

The **Top 10 Alert Level Evolution** chart shows a sharp single spike (rather than steady background noise) — characteristic of an automated tool, not human logins. The **Top 10 MITRE ATT&CK** breakdown is dominated by **Account Access**, with **Valid Accounts**, **Password Guessing**, **Remote Services**, and **SSH** all represented.

Representative alert rules triggered

Rule ID	Description	Level	Count
60122	Logon Failure — unknown user or bad password	5	10,697
204	Agent event queue is flooded (volume of events)	12	4
203	Agent event queue is full — events may be lost	9	4
5760	sshd: authentication failed	5	1

5715	sshd: authentication success	3	1
5503	PAM: user login failed	5	1
5557	unix_chkpwd: password check failed	5	1

Full alert breakdown is included in the appended Wazuh Threat Hunting Report.

5. Vulnerability Assessment

Field	Detail
Finding	SSH exposed to unrestricted password brute-forcing of a privileged account
Severity	CRITICAL
CVSS 3.1 (est.)	9.8 — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Affected asset	10.10.10.20 (SSH service, port 22)
Attack vector	Network — remote, unauthenticated

Description. The SSH service accepts password authentication for the root account and applies no controls to limit repeated failed attempts. An attacker on the network can therefore run an unlimited automated dictionary attack. Against a weak or common password, account compromise — and, for root, full system takeover — is only a matter of time.

6. MITRE ATT&CK Mapping

Tactic	Technique	ID
Credential Access	Brute Force	T1110
Credential Access	Brute Force: Password Guessing	T1110.001
Defense Evasion / Persistence	Valid Accounts	T1078
Lateral Movement / Initial Access	Remote Services: SSH	T1021.004

7. Root Cause Analysis

#	Root cause	Why it matters
1	Password authentication enabled for SSH	Passwords are guessable; keys are not
2	Direct root login permitted	Targets the highest-privilege account directly
3	No rate-limiting / account lockout	Allows unlimited rapid guesses
4	No MFA	A correct password alone grants access
5	Weak/common password policy	Vulnerable to wordlists like rockyou.txt

8. Remediation — Steps to Avoid

The target is a **Windows 11 host running OpenSSH for Windows**, so remediation uses Windows tooling — the OpenSSH server config lives at `C:\ProgramData\ssh\sshd_config` and there is no root account, Fail2Ban, or PAM on this platform.

Harden OpenSSH for Windows (`C:\ProgramData\ssh\sshd_config`)

```
PasswordAuthentication no      # require SSH keys instead of passwords
PubkeyAuthentication yes
MaxAuthTries 3                 # limit attempts per connection
LoginGraceTime 20
AllowUsers adminuser           # explicit allow-list (no broad access)
DenyUsers root administrator  # block high-value account names
```

Apply with (elevated PowerShell): `Restart-Service sshd`. For admin key auth, place keys in `C:\ProgramData\ssh\administrators_authorized_keys`.

Add brute-force protection (Windows)

- **Account Lockout Policy** — lock an account after N failed attempts via `secpol.msc` (Account Lockout Policy) or `net accounts /lockoutthreshold:5 /lockoutduration:15`.
- **Windows Defender Firewall** — block/throttle the source IP and restrict inbound port 22 to trusted hosts (`New-NetFirewallRule`).
- **Key-based authentication + passphrase** — eliminates password guessing entirely (OpenSSH supports it natively on Windows).
- **Multi-factor authentication** — e.g. Duo or a smart-card / Windows Hello for Business gate on remote access.
- If SSH isn't required, **remove the feature entirely**: `Remove-WindowsCapability -Online -Name OpenSSH.Server~~~~0.0.1.0`.

Reduce exposure

- Restrict OpenSSH to management subnets/VPN via Windows Defender Firewall — never expose it broadly.
- Change SSH from the default port 22 in `sshd_config` (reduces automated noise; not a control on its own).
- Enforce a strong Windows password policy (length + complexity) via Group Policy / `secpol.msc`.

Detection & response (Blue Team)

- Tune a Wazuh rule/alert for a threshold of failed logons in a short window (Windows logon-failure rule 60122, plus sshd rules 5710/5712 frequency correlation).
- Enable **Wazuh Active Response** to automatically firewall-drop an attacking IP on detection (the net sh/firewall command works on Windows agents).
- Alert on the first successful login that immediately follows a burst of failures (possible successful brute force).

9. System Hardening

Beyond fixing the specific SSH weakness, the following baseline hardening reduces the overall attack surface of every host. Controls are grouped by area and apply to both the Linux and Windows systems in the environment.

9.1 Patch & update management

- **Linux:** keep packages current and enable automatic security updates.
- **Windows:** stay current via Windows Update; track and approve patch hashes for allowlisting.

```
sudo apt update && sudo apt upgrade -y  
sudo apt install unattended-upgrades && sudo dpkg-reconfigure unattended-upgrades
```

9.2 Account & privilege hardening

- Enforce a strong password policy and account lockout (pam_pwquality / pam_faillock on Linux; Account Lockout Policy on Windows).
- Apply least privilege — remove unused and local admin accounts, restrict sudo to named users.
- Require **MFA** for all remote and privileged access.

9.3 Service & network minimization

- Disable unused services and close unused ports.
- Enforce a **default-deny host firewall**, allowing only required traffic.
- Segment the network (already implemented via the isolated Namek network).

```
sudo systemctl disable --now <unused-service>  
sudo ufw default deny incoming && sudo ufw allow 22/tcp && sudo ufw enable
```

9.4 Authentication & remote access

- **SSH:** key-based auth, no root login, limited attempts (see Section 8).
- **RDP:** require Network Level Authentication, restrict to VPN/management subnets, enforce strong credentials + lockout.

9.5 Application control (allowlisting)

- Deploy **deny-by-default application allowlisting** — Windows Defender Application Control / AppLocker, or a Zero Trust product — approving software by hash.
- This pairs directly with the SHA-256 hashes Sysmon captures (Section 10): every executed binary can be verified against the approved list.

9.6 Logging, auditing & monitoring

- Enable `auditd` (Linux) and **Sysmon** (Windows), forwarding both to Wazuh.
- Turn on **Wazuh File Integrity Monitoring (FIM)** for critical files and directories.

9.7 Configuration benchmarking

- Run **Wazuh Security Configuration Assessment (SCA)** against the **CIS Benchmarks** to score each host, identify misconfigurations, and track hardening drift over time.

10. Endpoint Telemetry Correlation (Sysmon)

To corroborate the authentication-failure evidence at the process level, **Sysmon** was deployed on the Windows target (windows-cli01) and its Microsoft-Windows-Sysmon/Operational channel forwarded to Wazuh. This is significant because the target **runs OpenSSH for Windows** — so the Hydra SSH attack is observable both as Windows authentication failures *and* as host-side process activity.

Sysmon's **Event ID 1 (Process Create)** recorded repeated executions of the OpenSSH daemon as it forked to service each incoming Hydra connection, complete with binary hash and parent lineage:

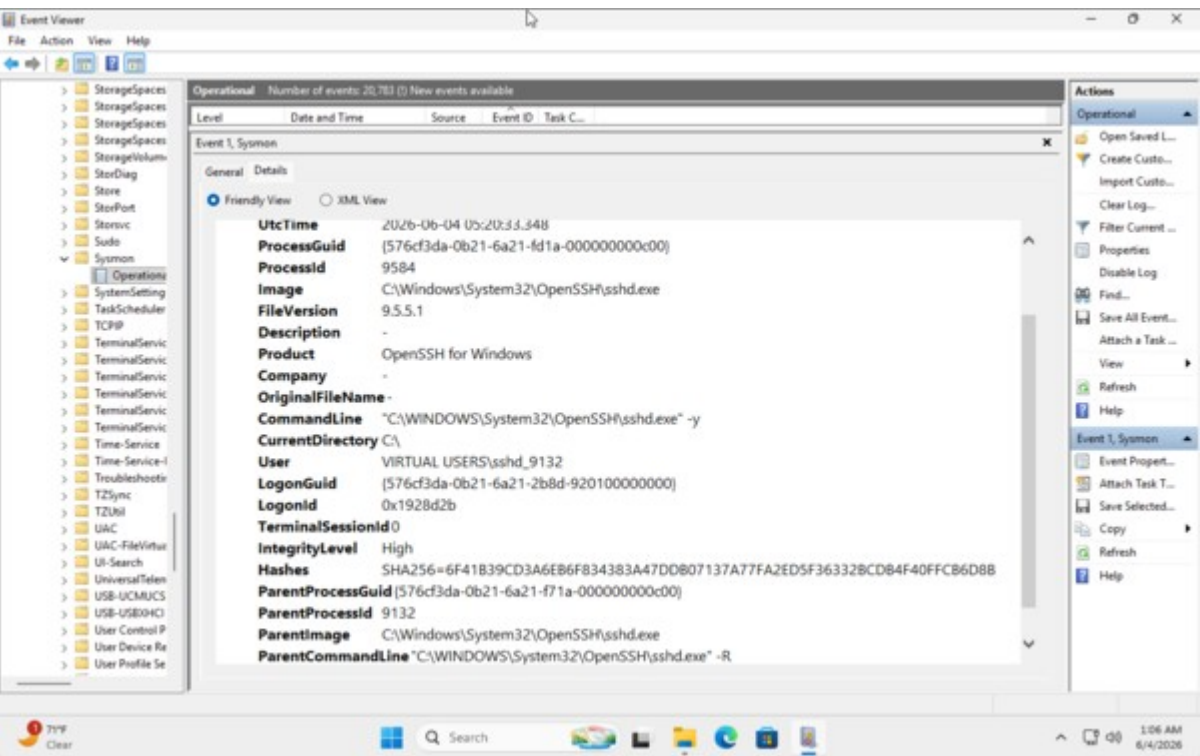


Figure 2 — Sysmon Process Create event for sshd.exe (full-resolution image in the repo's assets/).

Sysmon field	Value
Event ID	1 — Process Create
Image	C:\Windows\System32\OpenSSH\sshd.exe
Product / Version	OpenSSH for Windows — 9.5.5.1
Parent	sshd.exe -R (daemon servicing a connection)
User	VIRTUAL USERS\sshd_*
Integrity	High

level

SHA-256 6F41B39CD3A6EB6F834383A47DDB07137A77FA2ED5F36332BCDB4F40FFCB6D8B

Host windows-cli01

Correlation: the flood of short-lived `sshd.exe` child processes (Sysmon, what *ran*) lines up with the ~10,700 authentication failures (Wazuh, what *failed*) in the same window — two independent data sources confirming the same brute-force. Capturing each process's SHA-256 also enables allowlist / threat-intel checks on everything that executed.

11. Conclusion

This exercise closed the full purple-team loop: an offensive brute-force attack was executed with Hydra and reliably detected by the Wazuh SIEM, which surfaced the activity as a clear authentication-failure spike with MITRE ATT&CK context. The underlying weaknesses — password-based SSH, direct root login, and the absence of brute-force protections — are straightforward to remediate. Applying the controls in Section 8 (key-based auth, no root login, Fail2Ban, MFA) would render this attack ineffective, and the detection tuning would catch any future attempts immediately.

Appendix follows: full Wazuh Threat Hunting Report (auto-generated).

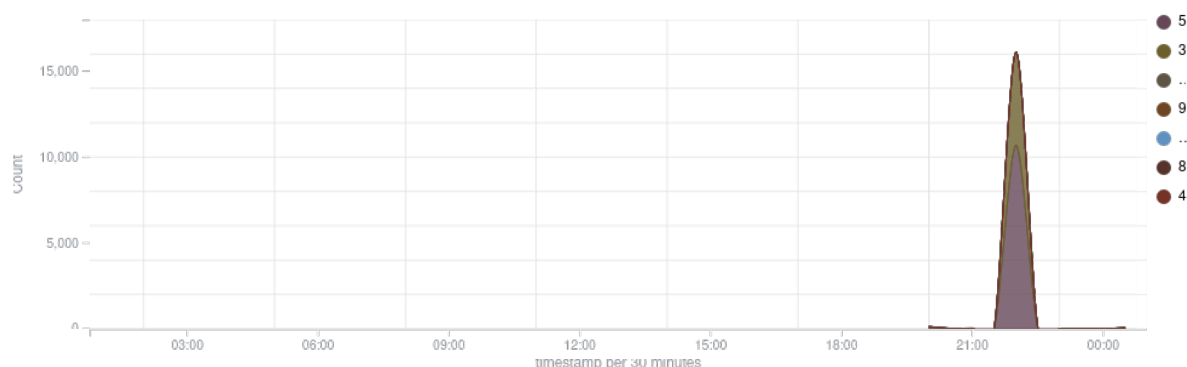
Threat hunting report

Browse through your security alerts, identifying issues and threats in your environment.

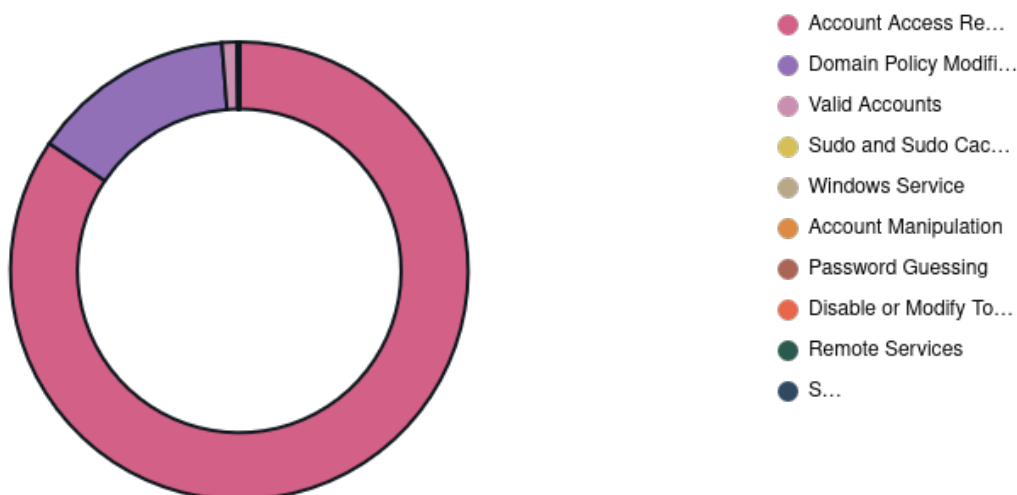
🕒 2026-06-03T00:45:47 to 2026-06-04T00:45:47

🔍 manager.name: ubuntu-srv01

Top 10 Alert level evolution



Top 10 MITRE ATT&CKS



Alerts evolution - Top 5 agents



16,420

- Total -

4

- Level 12 or above alerts -

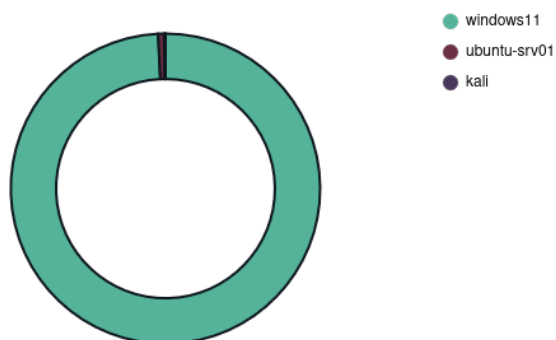
10,700

- Authentication failure -

136

- Authentication success -

Top 5 agents



Alerts summary

Rule ID	Description	Level	Count
60122	Logon Failure - Unknown user or bad password	5	10697
67028	Special privileges assigned to new logon.	3	1820
67023	Non service account logged off.	3	1802
67024	Service logon event registered from non standard service account.	3	1780
60106	Windows Logon Success	3	119
510	Host-based anomaly detection event (rootcheck).	7	64
60642	Software protection service scheduled successfully.	3	15
5502	PAM: Login session closed.	3	13
5501	PAM: Login session opened.	3	12
2902	New dpkg (Debian Package) installed.	7	7
2903	Dpkg (Debian Package) removed.	7	7
2904	Dpkg (Debian Package) half configured.	7	7
60646	License activation (slui.exe) failed.	5	7
203	Agent event queue is full. Events may be lost.	9	4
204	Agent event queue is flooded. Check the agent configuration.	12	4
503	Wazuh agent started.	3	4
5402	Successful sudo to ROOT executed.	3	4
60118	Windows Workstation Logon Success	3	4
60602	Windows application error event.	9	4
61138	New Windows Service Created	5	4
60775	SessionEnv was unavailable to handle a notification event.	5	3
60137	Windows User Logoff	3	3
61102	Windows System error event	5	3
202	Agent event queue is 90% full.	7	2
205	Agent event queue is back to normal load.	3	2
502	Wazuh server started.	3	2
52002	Apparmor DENIED	3	2
60109	User account enabled or created	8	2
60668	The Windows search service started.	3	2
60776	SessionEnv was unavailable to handle a critical notification event.	7	2
60808	The database engine is replaying log file C:\Winnt\system32\wins\j50.log.	3	2
60775	WSearch was unavailable to handle a notification event.	5	1
506	Wazuh agent stopped.	3	1
5403	First time user executed sudo.	4	1
5503	PAM: User login failed.	5	1
5557	unix_chkpwd: Password check failed.	5	1
5715	sshd: authentication success.	3	1
5760	sshd: authentication failed.	5	1
60110	User account changed	8	1

Rule ID	Description	Level	Count
60160	Domain Users Group Changed	5	1
60170	Users Group Changed	5	1
60200	IIS NetworkCleartext Logon Success	3	1
60702	The VSS service is shutting down due to idle timeout.	5	1
60798	The database engine attached a database.	3	1
60805	The database engine is starting a new instance.	3	1
60807	The database engine is initiating recovery steps.	3	1
60809	The database engine has completed recovery steps.	3	1
67018	System shutdown initiated.	3	1